

OS Command Injection

Injection 공격의 의미

Injection은 일반적인 데이터가 아닌 명령어(javascript, shell, SQL등)를 삽입해서 시스템이 의도되지 않은 동작을 하게하는 공격

종류

- OS Command Injection
- SQL Injection
- XSS
- CSRF

OS Command Injection 정의

웹 페이지에 일반적인 값 대신 시스템에서 특수한 동작으로 인식하는 문자열(CRLF==\r\n, &&, |, ;)과 함께 운영체제에서 사용되는 명령어를 삽입 함으로서 서버가 정상적이지 않은 동작을 하게끔 하는 공격

주로 해당 공격은 python의 `os.system()` 메서드처럼 명령어를 직접 실행시키는 코드에서 가능

예시 코드
import os

ip = [웹에서 사용자가 입력한 값]

os.system("ping -c 4 " + ip)

8.8.8.8 && cat /etc/passwd

Vulnerability: Command Injection

Ping a device

Enter an IP address.

Submit

패키지 설치

Ubuntu

```
apt -y install iputils-ping
```

Rocky

```
dnf -y install iputils
```

실습 진행

HTTP 요청 메서드

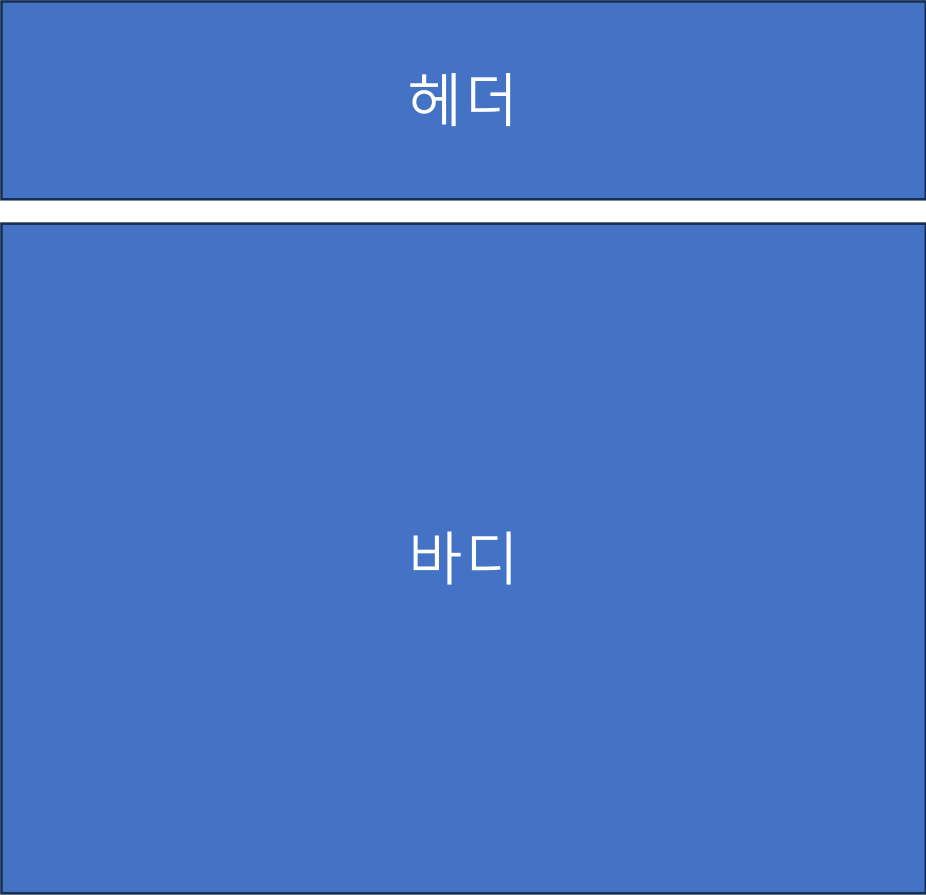
GET : 특정 자원을 요청할 때 사용

POST : 외부로 노출되면 안되는 값을 서버로 전달할 때 주로 사용

DELETE : 서버에 있는 특정 자원을 삭제할 때 쓰는 메서드

...

HTTP 메시지의 구조



The diagram illustrates the structure of an HTTP message. It consists of two main parts: a header and a body. The header is represented by a blue rectangular box at the top, containing the Korean word '헤더' (Header). Below the header is a larger blue rectangular box representing the body, containing the Korean word '바디' (Body). To the right of each box is a descriptive text in Korean.

헤더

주로 메시지에 대한 정보가 있는 곳
(HTTP 버전, 상태 코드, 요청 URL 등)

바디

전달할 데이터가 들어가는 공간
key=value 형식
단, GET 메서드는 바디가 없음

HTTP (GET)

GET : URL상에 전달할 값을 [파라미터 이름]=value 형태로 전달하는 방식, 외부에 노출되어 있음, 바디 부분이 없음

(URL에서 ? 다음에 나오는 것이 파라미터, &로 파라미터끼리 구분)

```
http://ww2.ubi.ck/vulnerabilities/sqli/?id=admin&Submit=Submit#
```

HTTP (POST)

POST : HTTP 바디 영역에 전달할 값을 key=value 형식으로 저장해서 전달하는 방식 (GET에 비해서 외부에 노출적으로 노출되어 있지는 않으나 패킷 분석을 통해서 확인 가능)

- ▼ HTML Form URL Encoded: application/x-www-form-urlencoded
 - ▼ Form item: "ip" = ";ls -al"
 - Key: ip
 - Value: ;ls -al
 - ▼ Form item: "Submit" = "Submit"
 - Key: Submit
 - Value: Submit